

Purple Team Outline

Week 12: AI/ML Security Basics

Objective: To think like an attacker to find flaws in application logic and server-side resource handling.

Task : AI Supply Chain & Prompt Elnjection Attacks

- **Description:** Learned the basics of AI/ML security risks through a hands-on assignment focused on attacks such as Prompt Injection and AI Supply Chain Attacks. Studied how these attacks work, their real-world impact, and the major security defenses and mitigation techniques used to protect AI systems.
- **Technical Requirements:**
 - Basic understanding of AI/ML concepts and common security risks in AI systems
 - Knowledge of Prompt Injection attacks and AI Supply Chain Security threats
 - Familiarity with secure coding practices and input validation techniques
 - Ability to analyze datasets, models, and dependencies for potential security vulnerabilities
 - Understanding of AI security defenses such as access control, dependency scanning, monitoring, and model verification

Prompt Injection Attacks:

Practical:

Select any intentionally vulnerable AI service, CTF challenge, lab environment, or local AI setup and clearly mention the name of the platform used along with introductory screenshots of the environment. Interact with the AI system using multiple prompts to observe and analyze how it responds to different types of instructions, including normal queries, manipulated prompts, and security-focused inputs. Evaluate whether the AI follows unauthorized instructions or demonstrates unsafe behavior when exposed to Prompt Injection techniques.

Attempt to identify vulnerabilities related to Prompt Injection or insecure instruction handling within a controlled and authorized testing environment. Demonstrate how specially crafted prompts can manipulate the AI into revealing restricted or sensitive information. In a CTF or sandboxed lab setup, examples may include retrieving hidden flags, system configuration details, internal prompts, environment variables, or files such as `/etc/passwd`. Ensure all testing is performed ethically and only on systems specifically designed or permitted for security research.

- Document the complete testing process step-by-step, including:
- The prompts used during each interaction
- The AI's responses and observed behavior
- The reasoning behind each prompt modification
- Any successful or failed exploitation attempts
- Screenshots of every important step, interaction, and result

Theory:

- Based on your practical testing, how did the AI system behave when exposed to manipulated or crafted prompts, and what observations indicated the presence or absence of Prompt Injection vulnerabilities?
- What sensitive or restricted information were you able to access (or attempt to access) during the exercise, and which prompts or techniques were most effective in influencing the AI's responses?
- Analyze the security weaknesses identified during the practical activity and explain which mitigation techniques or defenses could be implemented to prevent similar Prompt Injection or AI security attacks in real-world systems.

AI Supply Chain Security:

Practical:

Select any intentionally vulnerable AI platform, AI-powered application, lab environment, or local AI setup related to AI Supply Chain Security and clearly mention the name of the service along with introductory screenshots of the environment. Explore and analyze the behavior of the AI system by interacting with it using different prompts and inputs to understand how compromised datasets, vulnerable dependencies, poisoned models, or insecure third-party integrations can affect the AI's responses and overall behavior.

Investigate whether the AI system exposes any indicators of supply chain compromise, such as leaked training data, insecure dependencies, hidden prompts, exposed API keys, configuration details, manipulated outputs, or sensitive internal information resulting from a vulnerable component within the AI supply chain. Attempt to identify and document how the compromised component influences the AI model's responses and whether it leads to unintended data disclosure or abnormal behavior.

Demonstrate your findings within a controlled and authorized environment only. Clearly document:

- The vulnerable AI service or setup used
- The prompts or actions performed during testing
- The responses generated by the AI system
- Any sensitive information, leaked data, or abnormal behavior observed
- Indicators of dependency, dataset, or model compromise
- Screenshots of each important step, interaction, and finding throughout the activity

Theory:

- Based on your practical experiment, what abnormal behaviors or unexpected responses did you observe in the AI system that could indicate a potential AI Supply Chain Security issue (such as data poisoning, model tampering, or dependency compromise)?
- Which components of the AI supply chain (e.g., dataset, pretrained model, libraries, APIs, or deployment pipeline) appeared to have the highest risk impact during your testing, and how did they influence the AI's behavior or outputs?
- What evidence or findings from your observations suggest that sensitive information leakage or system manipulation may have occurred, and what steps would you recommend to detect and prevent such AI Supply Chain vulnerabilities in real-world systems?

Defensive Approach Against AI/ML Attacks:

- What is Prompt Injection, and why does separating system instructions from user input help in preventing such attacks? Explain in simple terms with an example.
- Describe at least three basic defensive techniques used to protect AI systems from Prompt Injection attacks, and explain how each one reduces risk.
- What is meant by AI Supply Chain Security, and why is it important to trust datasets, models, and third-party libraries used in AI systems?
- Explain how practices like dependency scanning, model verification, and data validation help prevent AI Supply Chain attacks. Give a simple example for each.
- Compare the defensive approaches for Prompt Injection attacks and AI Supply Chain attacks. How are they different, and where do they overlap in securing AI systems?